数据库安全性：安全标准、存取控制与审计

一、安全标准

1. TCSEC（1985年，核心考点）

分**A、B、C、D**四组7个等级，安全程度从D→A逐级提升，核心考点标注★

- D：最低等级，所有不满足更高标准的系统归为此类
- C1：初级自主安全保护，实现**DAC（自主存取控制）**，分离用户与数据，限制权限传播
- ★C2：安全产品最低档，细化DAC，支持个人身份注册、审计、资源隔离
- ★B1：真正意义上的安全产品，对数据标记，实现**MAC（强制存取控制）**
- B2：结构化保护，建立形式化安全策略模型，对所有主/客体实施DAC+MAC
- B3：安全域，TCB满足访问监控器要求，审计/跟踪能力强化
- A1：验证设计，基于B3级保护，增加系统形式化设计说明与验证

2. CC（1999年，国际标准）

按安全保证程度分**EAL1~EAL7** 7个等级，程度逐级升高，核心对应关系：

- EAL2 ↔ TCSEC-C1
- EAL7 ↔ TCSEC-A1

二、数据库安全性控制框架

1. 整体安全措施（层层设计）

用户身份鉴别 → 数据库管理系统（DBMS）安全保护 → 操作系统保护 → 敏感数据传输加密 → 数据库密码存储保护

2. DBMS安全控制模型

分为**事前、事中、事后、存储保护、传输保护**五类，核心围绕「身份验证-权限控制-操作审计」展开

三、用户身份鉴别（最外层安全保护）

1. 用户标识

由**用户名 + 唯一用户标识号**组成（标识号全系统生命周期唯一）

2. 4种鉴别方法

方法	核心特点	应用场景
静态口令	自定义、简单，可双因子（口令+数字证书）	常规用户日常登录
动态口令	一次一密、动态变化	临时访问、高安全需求场景
生物特征识别	指纹、掌纹、虹膜等唯一特征	高安全等级的身份验证
智能卡	不可复制硬件，常结合PIN码	线下终端、专用系统登录

四、存取控制机制（核心）

1. 机制组成（选择/填空考点）

1. 定义用户权限，将权限登记至**数据字典**（该过程称**授权规则/安全规则**）
2. 用户发起操作时，DBMS查询数据字典进行**合法权限检查**

> 两者共同组成DBMS的**存取控制子系统**

2. 自主存取控制（DAC，C1/C2级）

核心特点

用户对不同数据对象、不同用户对同一数据对象的权限均可差异化配置，通过SQL的`GRANT`（授权）和`REVOKE`（收回）实现。

（1）GRANT 授权语句

基本格式：

```
GRANT 权限1[, 权限2, ...]
ON 对象名
TO 用户1[, 用户2, ... | PUBLIC]
[WITH GRANT OPTION];
```

- 关键参数：
  - `PUBLIC`：表示授予**所有用户**该权限
  - `WITH GRANT OPTION`：允许被授权用户**转授**该权限给其他用户
  - 对**属性列**授权时，必须明确指定列名（如`UPDATE(Sno)`）
- 授权者范围：数据库管理员（DBA）、数据库对象创建者、拥有`WITH GRANT OPTION`的用户

（2）REVOKE 收回语句

基本格式：

```
REVOKE 权限1[, 权限2, ...]
ON 对象名
FROM 用户1[, 用户2, ... | PUBLIC]
[CASCADE];
```

- 关键参数（默认`RESTRICT`）：
  - `RESTRICT`：若被收回权限的用户已转授权限，**收回失败**
  - `CASCADE`：**级联收回**，不仅收回目标用户权限，还收回其转授给其他用户的同名权限

典型例题

1. 授予U1查询Student表的权限：`GRANT SELECT ON TABLE Student TO U1;`
2. 授予U5插入SC表的权限并允许转授：`GRANT INSERT ON TABLE SC TO U5 WITH GRANT OPTION;`
3. 级联收回U5插入SC表的权限：`REVOKE INSERT ON TABLE SC FROM U5 CASCADE;`

3. 强制存取控制（MAC，B1级，核心考点）

适用场景

军事、政府等对数据严格保密的部门，**必须先实现DAC，再叠加MAC。**

核心概念

- **主体**：系统活动实体（用户、代表用户的进程），标记为**许可证级别**
- **客体**：系统被动实体（文件、基本表、视图、索引），标记为**密级**
- **敏感级标记**（从高到低）：绝密（PS）> 机密（S）> 可信（C）> 公开（P）

核心存取规则（必记）

1. 仅当**主体许可证级别 ≥ 客体密级**时，主体**可读取**该客体
2. 仅当**主体许可证级别 ≤ 客体密级**时，主体**可写入**该客体

> 规则目的：防止高权限用户将敏感数据写入低密级对象，避免数据泄露。

关键特性

数据的密级标记与数据本身**不可分割**，无论数据如何复制，标记始终伴随，仅符合密级要求的用户可操作。

五、数据库角色

1. 核心定义

角色是权限的集合，用于简化对「具有相同权限的一组用户」的授权操作，与「用户」是不同概念。

2. 核心操作（SQL语句）

（1）创建角色

CREATE ROLE <角色名>;

（2）为角色授权（与用户授权格式一致）

GRANT <权限> ON <对象> TO <角色名>;

（3）将角色授予用户/其他角色

GRANT <角色名1> TO <用户/角色名2> [WITH ADMIN OPTION];

- `WITH ADMIN OPTION`：允许被授权者将该角色转授给其他用户/角色

（4）收回角色权限/角色

REVOKE <权限> ON <对象> FROM <角色名>;
REVOKE <角色名> FROM <用户/其他角色>;

典型例题

1. 创建角色R1：`CREATE ROLE R1;`
2. 为R1授予Student表的查/改/插权限：`GRANT SELECT,UPDATE,INSERT ON TABLE Student TO R1;`
3. 将R1授予王平、张明：`GRANT R1 TO 王平,张明;`

4. 收回王平的R1角色：`REVOKE R1 FROM 王平;`

六、视图机制（间接实现权限控制）

1. 核心作用

通过创建视图**隐藏保密数据**，仅向用户展示其有权限查看的内容，配合`GRANT/REVOKE`实现精细化权限控制。

2. 核心操作

（1）创建视图（带完整性检查）

CREATE VIEW <视图名> AS <查询语句> [WITH CHECK OPTION];

- `WITH CHECK OPTION`：对视图进行增/删/改时，强制检查数据是否满足视图的创建条件（如专业、年级）。

（2）对视图授权

与普通表的授权格式完全一致。

典型例题

创建计算机专业学生视图CS_Student，并授予王平查询权限、张明所有操作权限：

```
CREATE VIEW CS_Student AS
SELECT * FROM Student WHERE Smajor='计算机科学技术'
WITH CHECK OPTION;

GRANT SELECT ON CS_Student TO 王平;
GRANT ALL PRIVILEGES ON CS_Student TO 张明;
```

七、审计（事后安全控制，C2级及以上必带功能）

1. 核心定义

启用**专用审计日志**，记录数据库的所有操作（操作人、时间、内容、结果），由审计员监控日志，排查非法操作。

2. 核心特点

- 耗费系统时间和存储空间，DBA可根据安全需求**手动开启/关闭**
- 仅适用于安全性要求高的部门（军事、金融、政府）

3. 高频考点（必记）

1. **C2级及以上的DBMS必须具备审计功能**
2. 审计记录**必须先转储，再删除**（防止审计员误删/故意删除）
3. 转储后的审计记录文件需做**完整性+保密性保护**，仅审计员可查阅/转储，禁止任何用户新增/修改。

4. 审计相关SQL语句

- 设置审计：`AUDIT <操作类型> ON <对象> [BY ACCESS];`
- 取消审计：`NOAUDIT <操作类型> ON <对象>;`
- 审计类型：用户级审计（用户对自己创建的表/视图审计）、系统级审计（DBA操作，监控登录/系统权限等）

八、用户创建（CREATE USER，了解即可）

1. 超级用户（super user）

CREATE USER <用户名> WITH SUPERUSER [PASSWORD <密码>];

- 权限：可执行数据库所有操作，仅由系统初始化指定的超级用户创建。

2. 建库用户（CREATE DB）

CREATE USER <用户名> WITH CREATEDB [PASSWORD <密码>];

- 权限：可创建数据库并成为数据库属主，可创建模式并授予权限。

3. 普通用户

CREATE USER <用户名> PASSWORD <密码>;

- 权限：仅拥有被授予的基础操作权限。

核心总结（必背考点）

1. TCSEC核心：C2（安全产品最低档）、B1（真正安全产品，MAC）、DAC（C1/C2）、MAC（B1+）
2. 存取控制：DAC靠`GRANT/REVOKE`，MAC靠主/客体密级匹配，先DAC后MAC
3. 审计：C2及以上必备，记录先转储后删除，仅审计员可操作
4. 角色：权限集合，简化授权，`WITH ADMIN OPTION`控制角色转授
5. 视图：隐藏保密数据，配合授权实现精细化权限控制